

The Microsoft Root Certificate Program – Michael Waterman

 michaelwaterman.nl/2022/11/17/the-microsoft-root-certificate-program

Michael Waterman

November 17, 2022



A couple of days ago I had to deal with a situation where our vulnerability tool was complaining that the root certificate store wasn't updated for a while. This process runs every 7 days, so it takes some time before you will notice any error messages, as was in my case. After doing some research it turned out that the update service for the Microsoft root certificate program was blocked. That in turn triggered me to dig into the more technical side of the Microsoft Root certificate program.

In short the Root Certificate Program makes the end user experience a better one. When you visit an https enabled website a check is done if you trust the root authority that handed out the certificate (or the intermediate ca for that matter). If that root certificate is not in the "Trusted Root Certification Authorities" container a list of known participants of the root certificate program is checked if that Root CA is listed. If it is, the certificate is automatically downloaded and stored in the "Trusted Root Certification Authorities" local certificate store. Although it sounds like a good plan, it can be a bit confusing. In my case I work in a disconnected environment. Read, not being able to connect to Windows update. In that case you can tell Windows to use an internal web of file server to host the certificate list. The process is exactly the same in that case, it just uses a different repository. The confusing part was when I noticed that the location wasn't reachable however the root certificates were installed regardless. What kind of magic was at play here? Turns out that it isn't magic after all. Already with the introduction of Windows Vista, long long time ago Microsoft embedded the current list of Root certificates in the crypt32.dll. So if the

automatic root certificate process can't reach Windows update, an internal web or file server, it extracts the certificate from crypt32.dll. It took a while before I figured that one.

Looking at the current Root Certificates

When you have a freshly installed machine, there are already a few basic root certificates installed. Windows needs these to make initial secure communication possible to its own servers to provide telemetry information, Windows Activation or Windows updates. To see the initial list use the following PowerShell command. The preview here was done on a Windows Server 2019 machine, so your output could be different depending on the OS version and the time it has been in use:

```
Get-Childitem cert:\LocalMachine\root | select Friendlyname
```

PowerShell

```
PS C:\Users\Administrator> Get-Childitem cert:\LocalMachine\root | select Friendlyname

FriendlyName
-----
Microsoft Root Certificate Authority
Thawte Timestamping CA
Microsoft Root Authority

Microsoft Root Certificate Authority 2011
Microsoft Authenticode(tm) Root
Microsoft Root Certificate Authority 2010
Microsoft ECC TS Root Certificate Authority 2018
Microsoft Timestamp Root
VeriSign Time Stamping CA
Microsoft ECC Product Root Certificate Authority 2018
Microsoft Time Stamp Root Certificate Authority 2014
DigiCert Global Root G2
DigiCert Baltimore Root
DigiCert
VeriSign Class 3 Public Primary CA
```

Note! Don't make the mistake to remove older root certificates, especially the ones using Authenticode for signing. When signing a binary (as an example), the root certificate must be valid at the time of signing. It doesn't necessarily need to be valid after that time. If you put that Root Certificate in the Trusted Root Certificate store, the signing will be valid, even after the Root Certificate expires. Just for fun, use the following command to list the expired certificates, which still serve a valid purpose:

```
Get-ChildItem cert:\LocalMachine\root|Where {$_.NotAfter -lt (Get-Date).AddDays(30)}|select NotAfter, Subject
```

PowerShell

```
PS C:\Users\Administrator> Get-ChildItem cert:\LocalMachine\root|Where {$_.NotAfter -lt (Get-Date).AddDays(30)}|select
NotAfter, Subject
-----
10-5-2021 01:28:13 CN=Microsoft Root Certificate Authority, DC=microsoft, DC=com
1-1-2021 00:59:59 CN=Thawte Timestamping CA, OU=Thawte Certification, O=Thawte, L=Durbanville, S=Western Cape, C=ZA
31-12-2020 08:00:00 CN=Microsoft Root Authority, OU=Microsoft Corporation, OU=Copyright (c) 1997 Microsoft Corp.
1-1-2000 00:59:59 CN=Microsoft Authenticode(tm) Root Authority, O=MSFT, C=US
31-12-1999 00:59:59 OU=Copyright (c) 1997 Microsoft Corp., OU=Microsoft Time Stamping Service Root, OU=Microsoft Cor...
8-1-2004 00:59:59 OU="NO LIABILITY ACCEPTED, (c)97 VeriSign, Inc.", OU=VeriSign Time Stamping Service Root, OU="Ve...
```

Certificate validity

As I wrote in the previous paragraph, certificates expire, but certificates can also be revoked, even Root Certificates. This could be because the organization that manages the Root Certificate was breached, but could also have a very different reason. Normally your Certificate Revocation List (CRL) will take care of that, but it's always a good idea to do an additional check. As far as I know, Windows doesn't have a build in tool to verify Root Certificates as I have always used the Sysinternal SigCheck tool for this purpose. Lets first get the tool, open a PowerShell Window and use the following to download the tool:

```
wget https://download.sysinternals.com/files/Sigcheck.zip -OutFile SigCheck.zip -
UseBasicParsing
```

PowerShell

Note! the *"-UseBasicParsing"* must be omitted when IE is no longer installed on the machine (Which it shouldn't).

Unpack the zip file:

```
Expand-Archive .\SigCheck.zip
```

PowerShell

CD into the SigCheck directory and execute the following command:

```
sigcheck64.exe -tv -accepteula
```

BAT (Batchfile)

If you have a up-to-date system, including your CRL the output should be similar as displayed below.

```
Sigcheck v2.90 - File version and signature viewer
Copyright (C) 2004-2022 Mark Russinovich
Sysinternals - www.sysinternals.com

Listing valid certificates not rooted to the Microsoft Certificate Trust List:
No certificates found.
PS C:\Users\Administrator\SigCheck> _
```

Manage your internal Root Certificate list

As I said, it's entirely possible to manage your own Root Certificate list and not rely on the Dynamics of Windows Update. Use the following steps on your server to create an offline version of the Certificates available on Windows Update:

- Create a local folder and share it.
- Use: "`Certutil -syncWithWU \`" This will get all the appropriate data from Windows update site. Being:
 - Authrootstl.cab, contains a non-Microsoft Certificate trust List (STL).
 - Disallowedcertstl.cab, contains a STL with untrusted certificates.
 - Disallowedcert.sst, contains a serialized certificate store (SST) for untrusted certificates.
 - Pinrulesstl.cab, contains a STL of certificate pinning rules (Windows 10 and higher).
 - Pinrulesstl.sst, contains a serialized certificate store (SST) for Certificate pinning.
 - *.crt, all individual root certificate files.

Download the Root Certificate list in one single file

It can be beneficial to have all the certificate files available in one big file. It will become clear in the paragraph on managing the certificates. For now execute the following command to download the certificates in a *.sst (**S**erialized **C**ertificate **S**to**r**e) format.

```
certutil.exe -generateSSTFromWU root.sst
```

BAT (Batchfile)

Note! the name is not relevant and could be anything.

Updates for the Root Certificate List

To take control of the update process, it's not just downloading the certificates and putting them on a share or webserver, it's also necessary to disable the update process itself. To do so, you could take advantage of a group policy object or setting the key value pair in the registry directly. The policy is located at:

Computer Configuration -> Administrative Templates -> System -> Internet Communication Management -> Internet Communication -> Turn off Automatic Root Certificates Update

The registry key/value pair is located at:

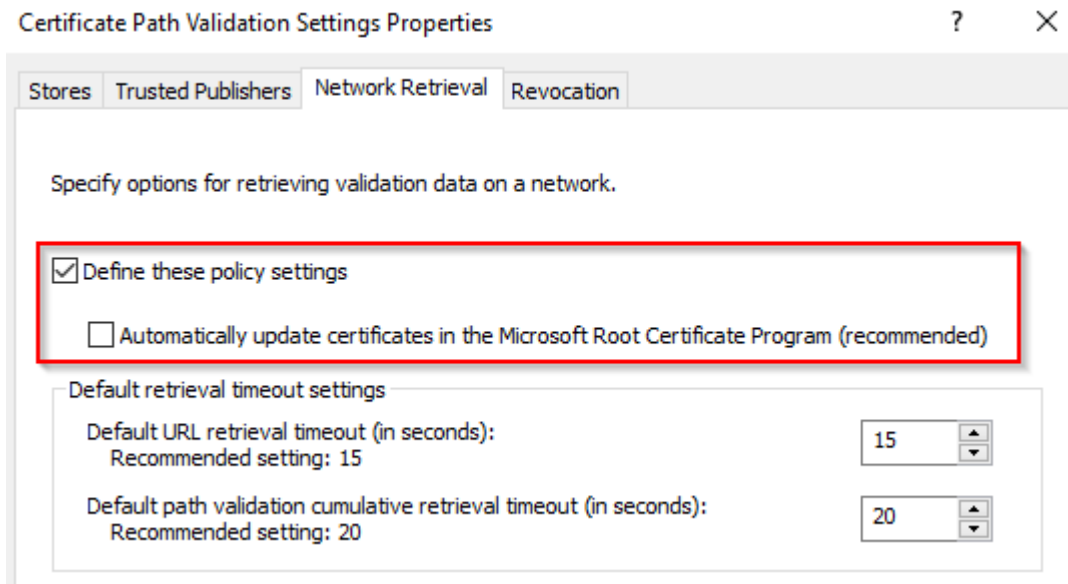
```
HKLM\Software\Policies\Microsoft\SystemCertificates\AuthRoot\DisableRootAutoUpdate=  
[0|1]
```

Windows Registry

Note! Setting this to 1 turns off the whole auto update mechanism for both trusted and untrusted certificates.

Note! There's a second way of disabling this setting:

Computer Configuration -> Windows Settings -> Security Settings -> Public Key Policies -> Certificate Path Validation Settings -> Network Retrieval



Select: "Define these policy settings" and deselect "Automatically update.....". Just don't use both methods to avoid confusion.

Distributing the certificates

Now that we have all the available root certificates available, we need a way to distribute them. There are four ways that we could do that:

1. Group Policy Object
2. Active Directory Container
3. File server
4. Web server

Group Policy Object

In the GPO Editor, navigate to

Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Public Key Policies -> Trusted Root Certification Authorities

Use the import function to place the *.cer files in the appropriate GPO. As you might have noticed you can only select one file at once, which makes this a lengthy process. However when you have policies in place to allow only a certain number of certificates, this is the

way to do it. Remember that, in the previous paragraph we downloaded all the certificates in one *.sst file? This is the moment to import it. In the “Certificate Import Wizard”, select the *.sst file when you browse the file system. Once all certificates are imported, do a multi-select on the files you don’t want to use, far easier than the other way around.

Active Directory Configuration Partition

When the granularity of Group Policy Targeting isn’t necessary, you could always publish the certificates directly to Active directory, much like you would do a publish of your own PKI root certificate.

```
certutil -dspublish -f <\filename>.crt RootCA
```

BAT (Batchfile)

Now, there isn’t a way that the *.sst file can be used with the dspublish parameter, so PowerShell to the rescue!

```
$certpath = "<path to the root certificate directory>"
$certificates = ( Get-ChildItem -Path $certpath -Filter "*.crt" )

foreach ($certificate in $certificates){
    certutil.exe -dspublish -f ($certificate.FullName) RootCA
}
```

PowerShell

Using AdsiEdit and navigating through the configuration partition, in the services node, we can locate the certificates in the “AIA” and “Certification Authorities” containers. On an end-node use gpupdate or wait for the group policy update cycle to process the root certificates.

File or webserver

When the previous methods aren’t a possibility there’s always a way to host the certificate files on a file or webserver. Store the certificate file on a share, for example in a sub directory of the SYSVOL share. Set the following registry key on your Client/Target point to your share:

```
HKLM\Software\Microsoft\SystemCertificates\AuthRoot\AutoUpdate\RootDirURL=file://\<servername>\SYSVOL\<domainname>\rootcert\
```

Windows Registry

Note! This can also be an internal webserver location. These setting are effective immediately.

Certificate Trust List

A “CTL” (Certificate trust List) is in essence a file that contains the hash values of certificates that are normally stored in the Trusted Root container. It’s important to remember that this list does not contain all the attributes of the original certificate but can be used for certain cryptographic operations where only the hash needs to be compared, such as signing verification operations. For those of you that are a bit more familiar with Public Key Infrastructure (PKI), a Certificate Revocation List (CRL) is a similar list, it only contains the hash values of the certificate, not the entire binary file. The Windows operating system, per default downloads the CTL every two weeks when there’s an update to download. If you need to manually download the file, use the following url:

<http://ctldl.windowsupdate.com/msdownload/update/v3/static/trustedr/en/authrootstl.cab>

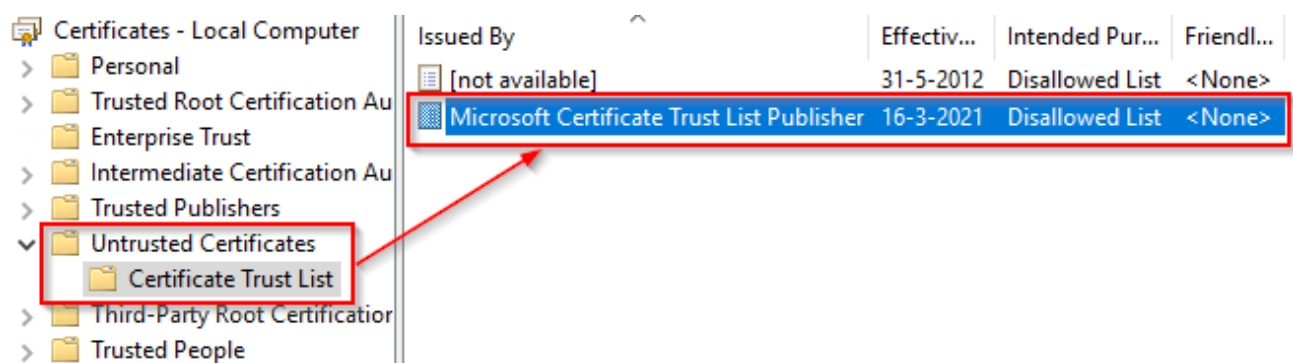
Or, if you also need to use the Certificate Revocation List for offline purposes, this is the url:

<http://ctldl.windowsupdate.com/msdownload/update/v3/static/trustedr/en/disallowedcertstl.cab>

The unfortunate part of this is that although you can publish the trusted stl list by using the “enterprise trust” in a GPO, I don’t know of a method to centrally distribute the disallowed certificate list. What is possible is using scripting around the following command:

```
certutil.exe -enterprise -f -v -AddStore disallowed <\path to disallowedcert.stl>
```

BAT (Batchfile)



Hint! In case you want to manage the untrusted certificate list from Active Directory, use the disallowedcert.sst instead.

Note! to only turn off the updating of the Disallowed Certificate list, use the following registry key:

```
HKLM\Software\Policies\Microsoft\SystemCertificates\AuthRoot\EnableDisallowedCertAutoUpdate=0
```

Windows Registry

Hint! To dump the entire certificate Trust list from your computer, use the following command:

```
certutil.exe -dump <\path\file.stl>
```

BAT (Batchfile)

Troubleshooting

If you are experiencing issues with certificate, don't worry, you're not alone. Even with the most reliable systems, unexpected problems can arise. In this section, we'll go over some common troubleshooting steps to help you diagnose and solve any issues you may encounter with the program. By following these steps, you can quickly get back on track and continue enjoying the benefits of a secure and trusted computing environment.

Clean the local downloaded cache

(Only with the Windows update download) locate the "CryptnetUrlCache" folder and delete the content. Usually in your user profile.

("%userprofile%\AppData\LocalLow\Microsoft\CryptnetUrlCache")

Enable CryptoAPI 2.0 Diagnostics

Enable the Capi2 event log (located in the "Applications and Services Logs") to get crypto operations logging.

Start a cryptographic operations

To initiate a crypto operation and see the automatic root certificate at work, browse to a HTTPS enabled website or open one of the certificates from the download mentioned above. Removing the certificate from the store and starting a crypto operation will reinitiate the process.

References

[Configure Trusted Roots and Disallowed Certificates | Microsoft Learn](#)